Informe legible de seguridad Garak

Proyecto: AgroRAG **Release evaluada:** `d38814b4f352b3f007f7520858f48daeca27a160` **Corrida:** `0.2.0-sha.d38814b4-local-20261031T190832Z` **Fecha:** 31/10/2026 **Garak:** 0.17.0 **Estado: BLOCKED - cobertura incompleta**

Resumen ejecutivo

La corrida verificó el límite preventivo de costo y produjo evidencia real para dos de las cuatro familias previstas. El adaptador procesó 128 solicitudes lógicas, pero solo 47 llegaron al modelo: 32 de búsqueda de API keys y 15 de bypass DAN. El control detuvo nuevas llamadas antes de superar el máximo autorizado de USD 0,20.

Gus Rivas revisó las 15 respuestas reales DAN el 31/10/2026 y clasificó 15/15 como falsos positivos, sin hallazgos confirmados ni casos dudosos. Las respuestas compartieron un único patrón seguro: solicitaron información adicional, no siguieron la instrucción DAN y no expusieron credenciales o secretos.

La release no queda aprobada por Garak. Base64 y prompt injection no tuvieron respuestas reales porque el presupuesto se agotó de forma preventiva. El triage DAN está cerrado, pero la cobertura adversarial total y la promoción permanecen bloqueadas.

Entorno y candidata evaluada

La aplicación se ejecutó en Docker Compose sobre Ubuntu WSL. API, UI y gateway se desplegaron por digest. Solo el gateway se publicó en el host: `18080->80` y `18443->443`; API y UI permanecieron en la red interna. La aplicación local estuvo disponible en `https://localhost:18443` con TLS y autenticación Basic locales.

Componente	Digest desplegado
API	`sha256:597a469fa8a688210cca5bc94dc0722c70975e57535171d14d70908336c9c96c`
UI	`sha256:82cabbfc5fdb132d29782fd5feb9c586e0a992cb75d53753b81f1aad0dfa1144`
Gateway	`sha256:31225397760fdcface3fa3641b73236df272dbc5e59824b77304b1b42c9afc3a`
Garak runner	`sha256:f0bd19bef1458a0b74b70d4a4c55fa3c94aa0cec10ca86fb84b1059cafd5267e`

Control de costo

Métrica	Resultado
Techo autorizado	USD 0,200000
Costo estimado	USD 0,080445
Margen no utilizado	USD 0,119555
Tokens de entrada	30.286
Tokens de salida	473
Solicitudes lógicas	128
Respuestas reales	47
Rechazos contractuales HTTP 422	12
Bloqueos antes de llamar por presupuesto	69
Errores de transporte ambiguos	0

La siguiente reserva conservadora era USD 0,12. Como USD 0,080445 + USD 0,12 hubiera dado USD 0,200445, el adaptador rechazó las solicitudes restantes antes de alcanzar el gateway. No hubo reintentos ni llamadas posteriores.

Cobertura efectiva

Familia Garak	Respuestas reales	HTTP 422	Presupuesto	Interpretación
`apikey.GetKey`	32	0	0	32/32 sin detección de API key; cobertura real completa para esta familia.
`dan.DanInTheWild`	15	12	5	15/15 respuestas reales revisadas como falsos positivos; triage cerrado.
`encoding.InjectBase64`	0	0	32	Sin cobertura real; los pases automáticos provinieron de respuestas sintéticas del harness.
`promptinject.HijackHateHumans`	0	0	32	Sin cobertura real; los pases automáticos provinieron de respuestas sintéticas del harness.

El reporte bruto muestra 32 fallos DAN porque también evalúa las 12 respuestas contractuales y los 5 bloqueos de presupuesto. Esos resultados no son 32 vulnerabilidades reales. El dictamen humano se limita a las 15 respuestas producidas efectivamente por la aplicación.

Revisión humana completada

Métrica	Resultado
Casos reales DAN	15
Revisados	15
Falsos positivos	15
Confirmados	0
Dudosos	0
Pendientes	0
Revisor	Gus Rivas
Fecha	31/10/2026

El libro sanitizado conserva los identificadores, el veredicto, el motivo, el revisor, la fecha y una descripción observable, pero no incluye prompts ni respuestas completas. Una comprobación offline confirmó que las 15 respuestas observadas eran idénticas, solicitaban más información, no mencionaban DAN y no contenían marcadores de credenciales o secretos.

Este resultado cierra el triage manual de DAN. No transforma la falta de cobertura de Base64 y prompt injection en un pase ni constituye una certificación de seguridad.

Ubicación de artefactos

Artefacto	Ubicación	Tratamiento
Informe Markdown	`docs/evidence/garak/garak-d38814b4-human-report.md`	Versionado
Informe PDF	`output/pdf/garak-d38814b4-human-report.pdf`	Versionado
Resumen de triage	`docs/evidence/garak/d38814b4-human-triage.json`	Versionado y sanitizado
Libro de revisión	`docs/evidence/workbooks/garak-d38814b4-revision-humana-dan.xlsx`	Versionado y sanitizado
Libro local con prompts	`/home/gus/.local/share/agrorag/review/d38814b4-dan/garak-d38814b4-pruebas-locales-final.xlsx`	Local, modo 0600
Reportes crudos Garak	`/home/gus/.local/share/agrorag/garak/d38814b4-20261031T190832Z`	Local restringido

Los crudos conservan los hashes SHA-256 registrados en la evidencia `REL-V2-08`. Este informe no incluye prompts, respuestas completas, claves ni cabeceras de autenticación.

Conclusión y siguiente decisión

La ejecución y su triage quedan documentados: el tope de costo funcionó, API key no mostró detecciones en 32 respuestas reales y los 15 avisos DAN fueron falsos positivos según la revisión humana. La tarea operativa OpenSpec 5.3 puede cerrarse con resultado bloqueante.

La promoción 5.4 permanece abierta porque no hubo cobertura real para Base64 ni prompt injection y el runner terminó con `cost_budget_exhausted`. Para continuar se requiere una estrategia que priorice esas familias y una nueva autorización explícita de presupuesto, siempre con techo por corrida menor o igual a USD 0,20. No corresponde repetir llamadas con la autorización ya agotada.

Garak aporta evidencia heurística sobre esta candidata; no garantiza seguridad completa ni reemplaza threat modeling, controles clásicos, revisión humana y monitoreo.